

Respuesta ante Ataques DDoS

- NIST SP 800-61
- MITRE ATT&CK
- SANS
- ISO/IEC 27035

PREPARACIÓN · CONTINUO

Baselines de tráfico actualizadas mensualmente · servicio anti-DDoS preconfigurado (activación <15 min) · contacto 24/7 con ISP documentado · protección anti-spoofing BCP38/BCP84.

FASE 1 **Detección y Análisis**

FASE 2 **Contención**

FASE 3 **Erradicación / Mitigación**

FASE 4 **Recuperación**

FASE 5 **Lecciones Aprendidas**

NOTACIÓN DEL DIAGRAMA



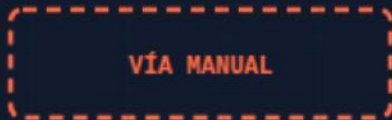
Círculo celeste
Inicio y fin del flujo



Rectángulo amarillo
Paso operativo



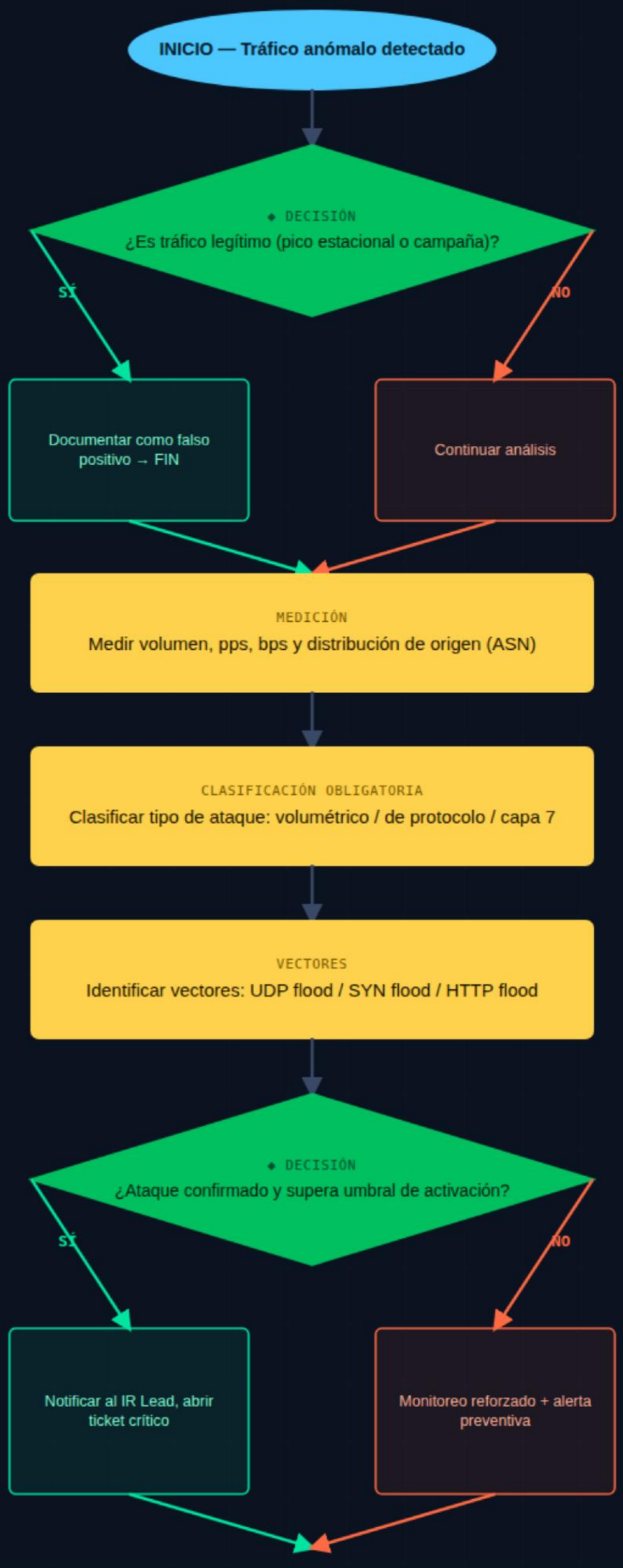
Rombo verde
Punto de decisión Sí / No



Recuadro punteado naranja
Contingencia manual

Respuesta ante Ataques DDoS

● FASE 1 – Detección y Análisis

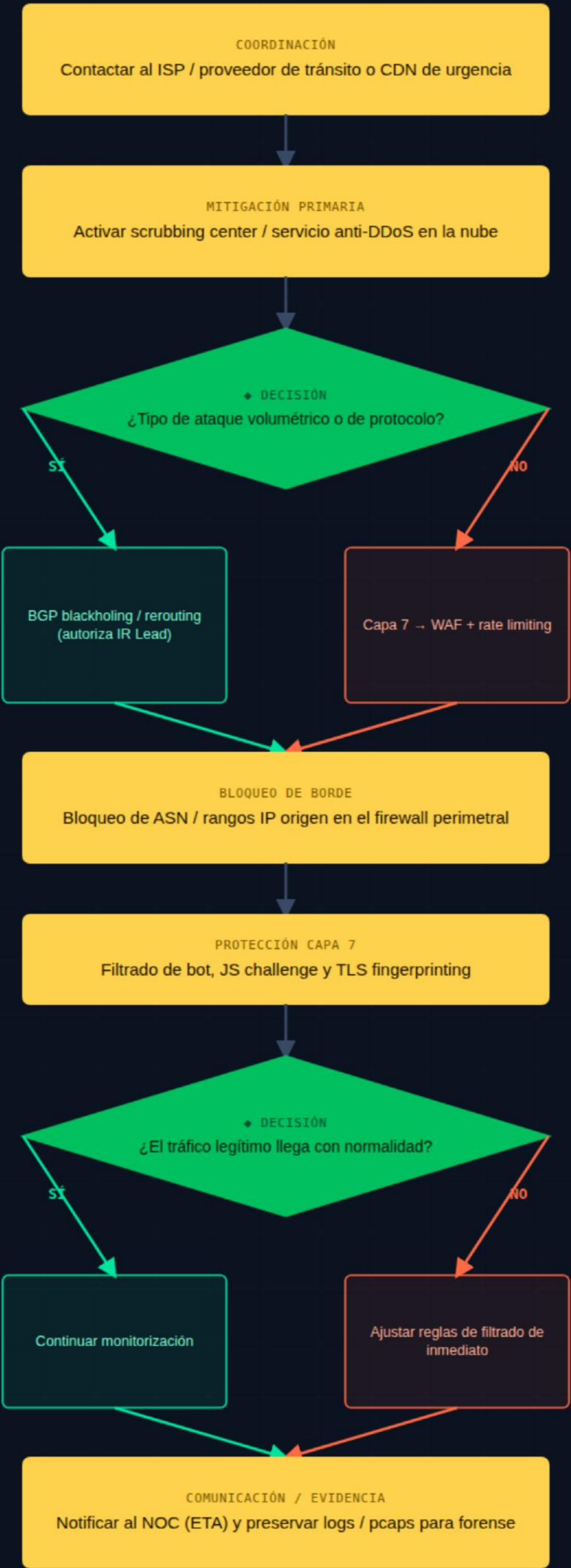


HERRAMIENTAS – DETECCIÓN Y ANÁLISIS

- ▶ Kentik Network Observability
- ▶ NetFlow / sFlow (en SIEM)
- ▶ Splunk Enterprise Security
- ▶ Suricata IDS
- ▶ PRTG / Zabbix

Respuesta ante Ataques DDoS

● FASE 2 – Contención

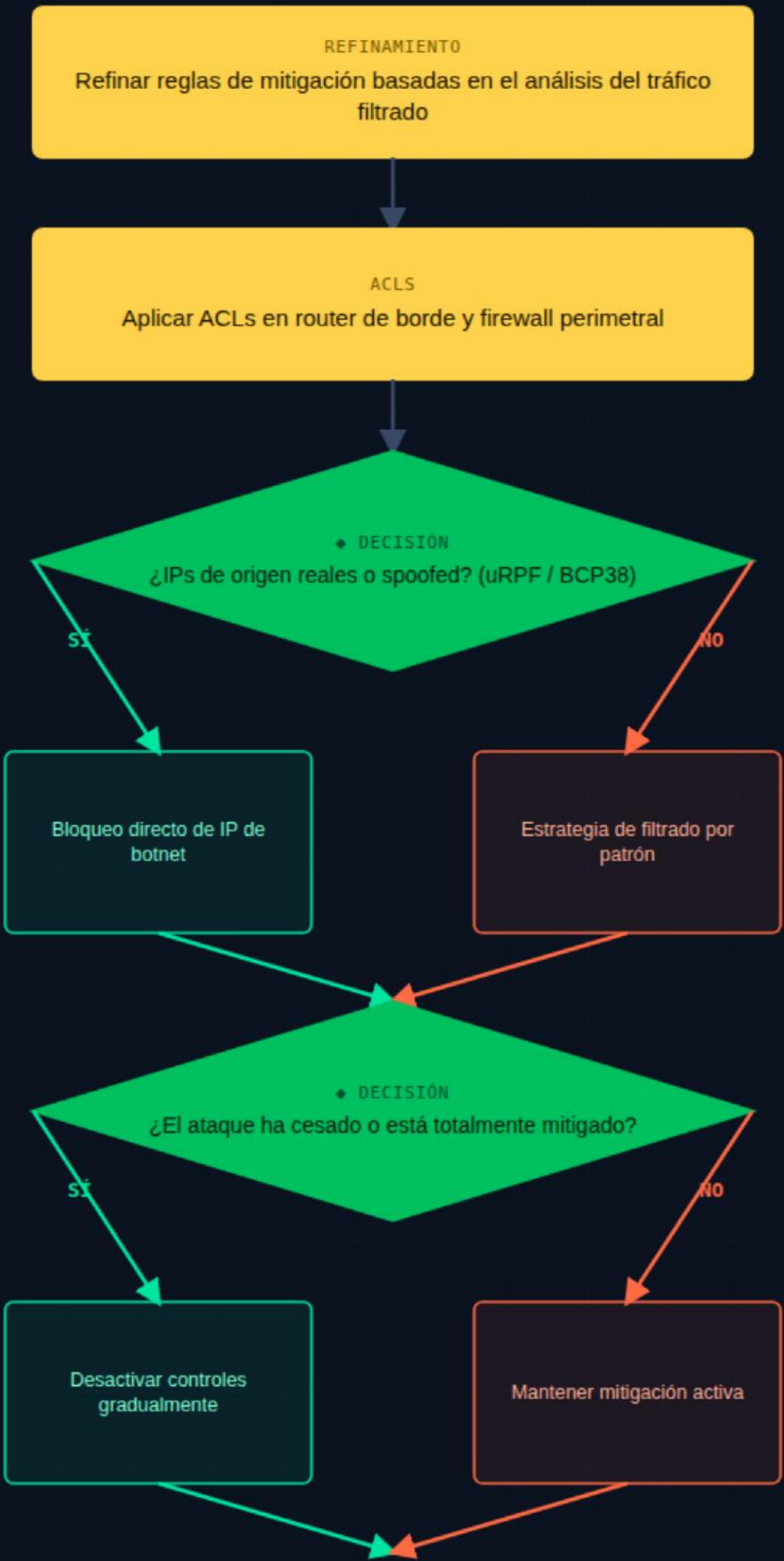


HERRAMIENTAS – CONTENCIÓN

- ▶ Cloudflare DDoS Protection
- ▶ AWS Shield Advanced
- ▶ F5 BIG-IP AFM
- ▶ Radware DefensePro
- ▶ Fortinet FortiDDoS

Respuesta ante Ataques DDoS

● FASE 3 – Erradicación / Mitigación

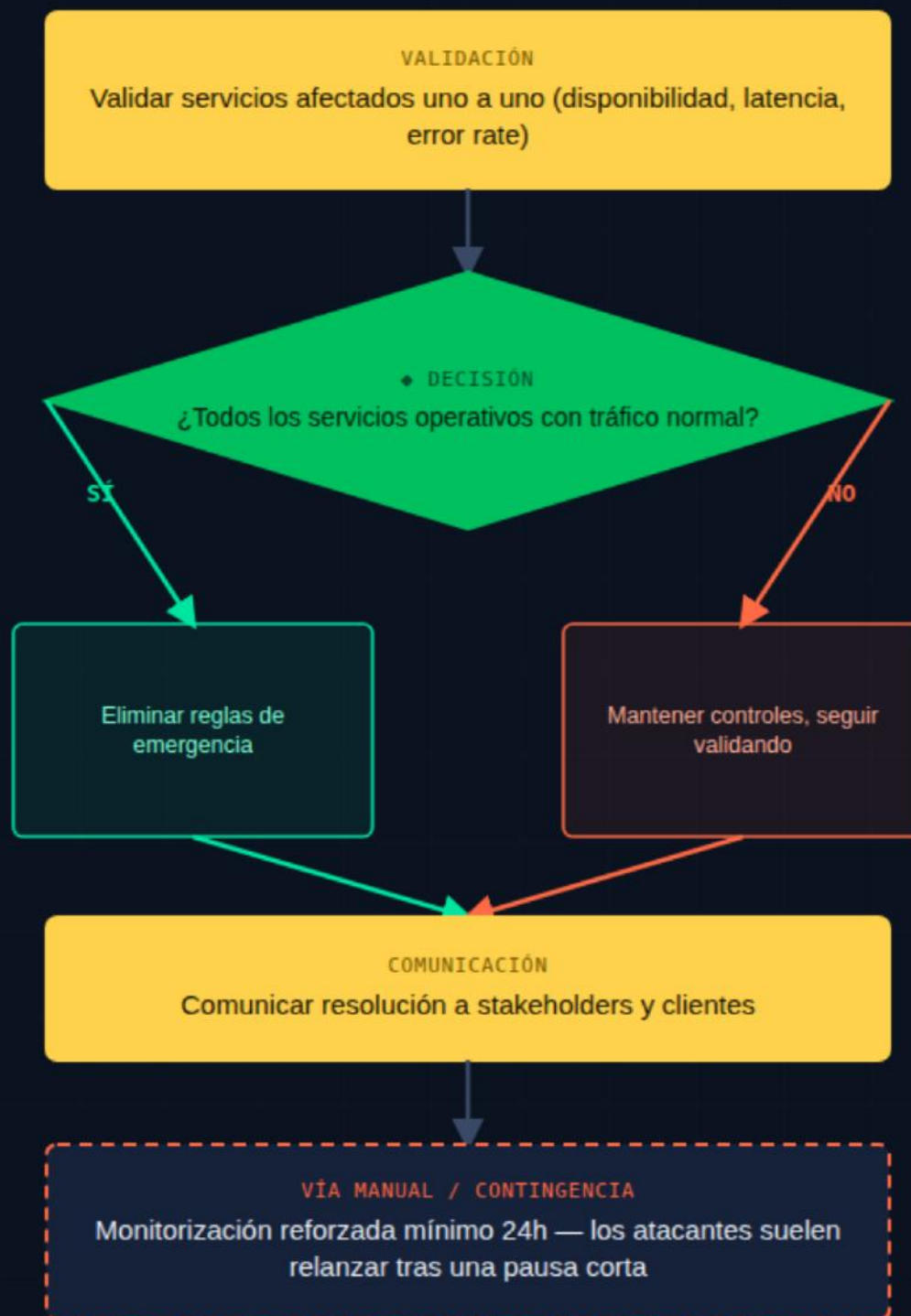


HERRAMIENTAS – ERRADICACIÓN / MITIGACIÓN

- Cloudflare WAF
- AWS WAF
- F5 BIG-IP ASM
- Palo Alto NGFW (ACLs avanzadas)

Respuesta ante Ataques DDoS

• FASE 4 – Recuperación

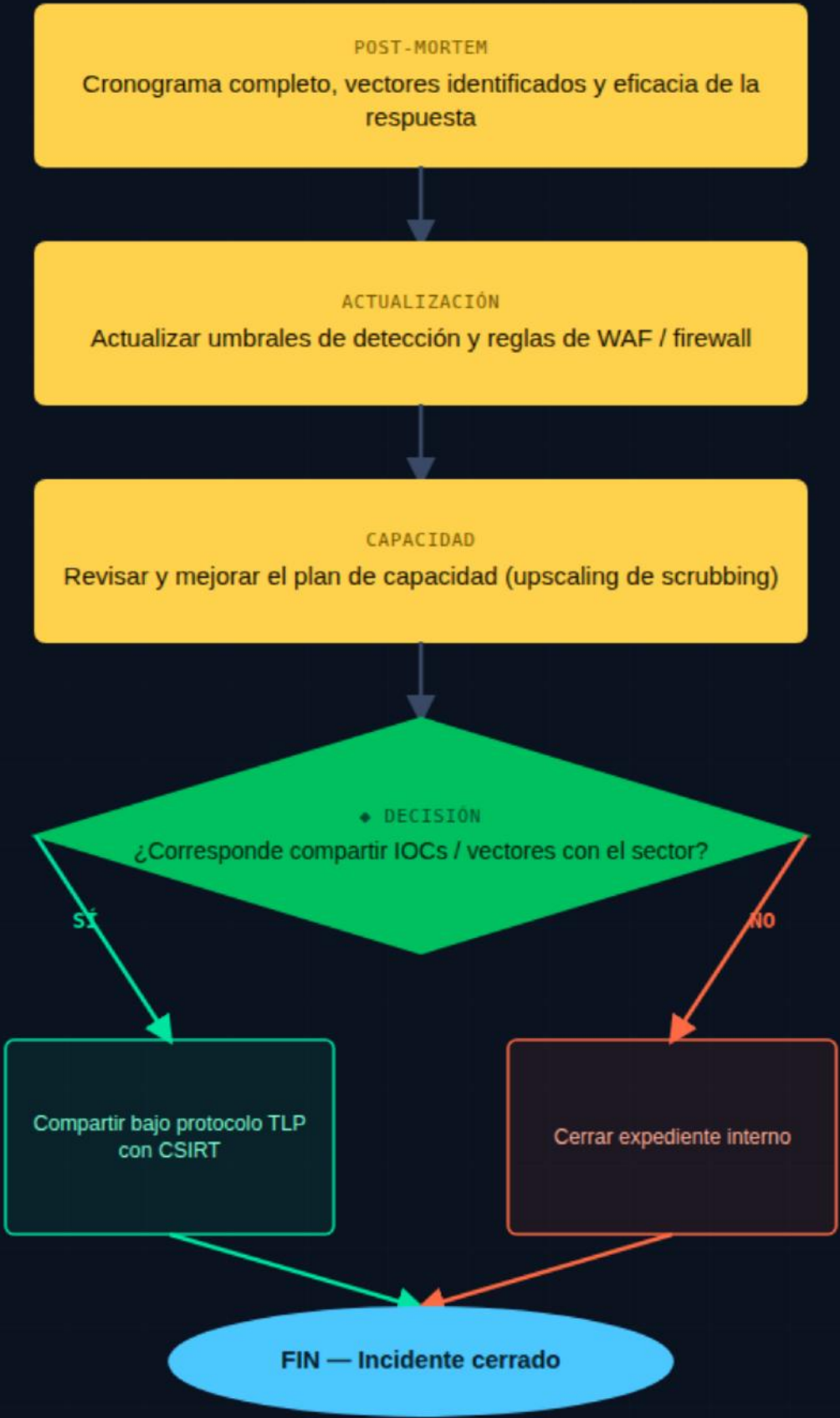


HERRAMIENTAS — RECUPERACIÓN

- Datadog
- Grafana + Prometheus
- PagerDuty
- Pingdom / UptimeRobot

Respuesta ante Ataques DDoS

● FASE 5 – Lecciones Aprendidas



HERRAMIENTAS – LECCIONES APRENDIDAS

- ▶ TheHive
- ▶ ServiceNow ITSM
- ▶ Jira Service Management
- ▶ Confluence

INFORME TÉCNICO DE DISEÑO Y COBERTURA

Playbook de Respuesta ante Ataques DDoS (SOC-IR-043)

Campo	Detalle
Documento de referencia	Playbook SOC-IR-043 — Versión 1.0 (documento independiente)
Tipo de documento	Informe técnico de diseño, metodología y cobertura
Clasificación	Confidencial / Uso Interno
Marcos de referencia	NIST SP 800-61 Rev. 2, MITRE ATT&CK, SANS Incident Handler's Handbook, ISO/IEC 27035
Fecha del informe	21 de junio de 2026
Elaborado por	Asistente de Ciberseguridad Defensiva (Blue Team)

Nota: el procedimiento operativo completo se entrega como documento independiente: *Playbook de Respuesta ante DDoS — SOC-IR-043 v1.0*. Este informe documenta la metodología de diseño, las consideraciones específicas de un ataque DDoS y la verificación de cobertura frente a la checklist de nueve elementos.

1. Resumen Ejecutivo

El playbook SOC-IR-043 fue diseñado para cubrir de forma completa el ciclo de vida de respuesta ante ataques de Denegación de Servicio Distribuido (DDoS), alineado con NIST SP 800-61 Rev. 2. A diferencia del ransomware o el phishing, los ataques DDoS no comprometen datos ni sistemas internos de forma directa: su impacto se mide en tiempo de indisponibilidad y degradación de servicios, lo que hace que la velocidad de activación de la mitigación (MTTC) sea la métrica más crítica, por encima incluso del análisis forense.

El playbook distingue desde el triage inicial tres tipos de ataque (volumétrico, de protocolo y de capa 7) porque cada uno requiere técnicas de mitigación específicas: BGP blackholing para ataques volumétricos, protección TCP SYN proxy para ataques de protocolo, y WAF con rate limiting y CAPTCHA para ataques de capa de aplicación. Aplicar una técnica de mitigación incorrecta puede resultar en un bloqueo de tráfico legítimo (denegación de servicio auto-infligida) o en una mitigación ineficaz que prolonga el impacto.

El playbook cubre los nueve elementos que un Procedimiento Operativo Estándar (POE) debe contener y se entrega listo para operacionalización, sujeto a la parametrización de umbrales de tráfico específicos de la organización.

2. Alcance y Metodología de Diseño

El playbook SOC-IR-043 se desarrolló aplicando la misma checklist de nueve elementos utilizada en los playbooks anteriores (SOC-IR-042 Ransomware, SOC-IR-041 Phishing), derivada de los siguientes marcos de referencia:

- **NIST SP 800-61 Rev. 2** — ciclo de vida de gestión de incidentes.
- **MITRE ATT&CK** — tácticas de Impact (TA0040): T1498 Network Denial of Service y T1499 Endpoint Denial of Service, con sus sub-técnicas.
- **SANS Incident Handler's Handbook** — estructura PICERL y buenas prácticas operativas.
- **ISO/IEC 27035** — gestión de incidentes, roles, comunicación y mejora continua.

Los nueve elementos de diseño verificados: (1) nombre y alcance, (2) triggers de activación, (3) roles y responsables, (4) fases del proceso según el ciclo NIST, (5) acciones técnicas concretas por fase, (6) mapeo a MITRE ATT&CK, (7) criterios de escalado, (8) pautas de comunicación y (9) métricas de cierre.

3. Consideraciones de Diseño Específicas de DDoS

Un ataque DDoS presenta particularidades frente a otros tipos de incidente que condicionaron decisiones de diseño concretas en el playbook:

- **Clasificación triple desde el triage:** el playbook distingue desde el inicio entre ataques volumétricos, de protocolo y de capa 7. Esta bifurcación es crítica porque la herramienta correcta para mitigar un SYN flood (SYN proxy en el firewall) es completamente distinta de la necesaria para un HTTP flood (WAF con rate limiting), y usar la herramienta equivocada prolonga el ataque o afecta al tráfico legítimo.
- **Riesgo de denegación de servicio auto-infligida:** se incorporó un punto de control explícito (¿el tráfico legítimo llega con normalidad?) con una vía de ajuste de reglas antes de continuar con la erradicación. Bloquear rangos de IP demasiado amplios puede impactar a usuarios reales más que el propio ataque.
- **Baselines de tráfico como prerequisite:** sin un baseline actualizado de tráfico normal, es imposible distinguir un ataque de un pico legítimo (lanzamiento de producto, campaña de marketing). El playbook lo incluye en Preparación como un requisito operativo, no opcional.
- **BGP blackholing como medida de último recurso:** se documenta explícitamente que el blackholing de un prefijo implica aceptar la indisponibilidad total de esa IP como mal menor frente a la saturación del enlace, lo que requiere autorización del IR Lead. No es una medida que pueda aplicar el L1 de forma autónoma.
- **Coordinación ISP como paso crítico no técnico:** a diferencia del ransomware o el phishing, la mitigación de ataques volumétricos de gran escala requiere coordinación con un tercero externo (ISP o proveedor de tránsito) que no pertenece a la cadena de mando interna. El playbook define este canal de comunicación como parte del escalado, con contactos preestablecidos en Preparación.
- **Riesgo de reactivación post-incidente:** se incorpora en la fase de Recuperación una monitorización reforzada de al menos 24 horas, ya que los atacantes frecuentemente relanzan el ataque tras una pausa corta una vez detectan que los controles de emergencia se han desactivado.

4. Cobertura frente a la Checklist de Nueve Elementos

La siguiente tabla confirma dónde se aborda cada uno de los nueve elementos dentro del Playbook SOC-IR-043:

#	Elemento de la checklist	Sección en Playbook SOC-IR-043 v1.0
1	Nombre y alcance del playbook	Sección 2 — Alcance y Marco de Referencia
2	Triggers de activación	Sección 3 — Trigger / Criterios de Activación
3	Roles y responsables	Sección 4 — Roles y Responsables (incluye proveedor anti-DDoS externo y NOC)
4	Fases del proceso según el ciclo NIST	Sección 6 — Fases del Proceso (6.0 a 6.5)

#	Elemento de la checklist	Sección en Playbook SOC-IR-043 v1.0
5	Acciones técnicas concretas por fase	Sección 6, con detalle adicional en el diagrama de flujo granular
6	Mapeo a MITRE ATT&CK	Sección 7 — Mapeo a MITRE ATT&CK (T1498, T1499 y sub-técnicas)
7	Criterios de escalado	Sección 9 — Criterios de Escalado (incluye vía ISP y proveedor anti-DDoS)
8	Pautas de comunicación	Sección 10 — Comunicación (incluye página de estado de servicio)
9	Métricas de cierre	Sección 11 — Métricas de Cierre (MTTD, MTTC, MTTR + volumen máximo)

El Playbook SOC-IR-043 incluye además el diagrama de flujo granular con opciones de herramientas por fase, la tabla de herramientas y configuraciones críticas, y su propio control de versiones.

5. Recomendaciones y Próximos Pasos

1. Parametrizar los umbrales de activación de la sección 3 con valores reales de la organización (Gbps y Mpps máximos observados en tráfico legítimo), ya que el playbook los incluye como variables a completar.
2. Establecer y documentar el contacto de urgencia 24/7 con el ISP y el proveedor anti-DDoS antes de que el playbook entre en producción, y verificar los SLAs de activación comprometidos.
3. Ejecutar un simulacro de activación del servicio anti-DDoS en la nube en modo de prueba para validar el tiempo real de activación y el comportamiento del enrutamiento BGP.
4. Construir o actualizar las baselines de tráfico por servicio como requisito previo a la operacionalización del playbook.
5. Revisar y actualizar este playbook con periodicidad semestral o tras cualquier ataque DDoS significativo.
6. Aplicar esta misma checklist de nueve elementos al resto de playbooks pendientes del catálogo del SOC.

6. Historial del Informe

Versión	Fecha	Cambios	Autor
1.0	21 jun. 2026	Versión inicial: metodología de diseño, consideraciones específicas de DDoS (clasificación triple, riesgo de auto-denegación, coordinación ISP) y verificación de cobertura frente a la checklist de nueve elementos	Asistente de Ciberseguridad Defensiva

CONFIDENCIAL — USO INTERNO

PLAYBOOK DE RESPUESTA ANTE INCIDENTES

Procedimiento Operativo Estándar frente a Ataques DDoS

SOC-IR-043 · Versión 1.0

Código	SOC-IR-043
Versión	1.0
Clasificación	Confidencial / Uso Interno
Estado	Vigente
Marcos de referencia	NIST SP 800-61 Rev. 2 · MITRE ATT&CK · SANS · ISO/IEC 27035
Última revisión	21 de junio de 2026
Autor	Equipo de Ingeniería del SOC
Aprobado por	CISO

1. Resumen Ejecutivo

Este playbook establece el procedimiento operativo estándar para detectar, clasificar, contener y mitigar ataques de Denegación de Servicio Distribuido (DDoS) dirigidos a la infraestructura de red, aplicaciones web o servicios expuestos de la organización. Cubre el ciclo completo de gestión de incidentes conforme a NIST SP 800-61 Rev. 2, diferenciando desde el triage inicial entre tráfico legítimo inusual (falso positivo), ataques volumétricos/de protocolo y ataques de capa de aplicación (capa 7), ya que cada tipo requiere herramientas y técnicas de mitigación distintas.

A diferencia del ransomware o el phishing, los ataques DDoS no comprometen datos ni sistemas internos de forma directa: su impacto se mide exclusivamente en tiempo de indisponibilidad. Por ello el MTTC (tiempo hasta la mitigación activa) es la métrica más crítica de este playbook, por encima incluso del análisis forense.

!

Usar la herramienta de mitigación incorrecta para el tipo de ataque puede resultar en una denegación de servicio AUTO-INFLIGIDA: bloquear tráfico legítimo más que el propio ataque. La clasificación del tipo de ataque es OBLIGATORIA antes de activar cualquier medida de mitigación.

2. Alcance y Marco de Referencia

Nombre: Respuesta ante Ataques de Denegación de Servicio Distribuido (DDoS)

Código: SOC-IR-043 · Versión 1.0

Cubre: ataques volumétricos (UDP flood, ICMP flood, amplificación DNS/NTP), ataques de protocolo (SYN flood, IP fragmentation) y ataques de capa 7 (HTTP flood, Slowloris, scraping masivo) dirigidos a activos expuestos de la organización.

No cubre: caídas de servicio por fallos internos sin componente de ataque externo (ver procedimiento de gestión de disponibilidad), ni ataques de ransomware que incluyan un componente DDoS como distracción (ver SOC-IR-042).

Marcos de referencia:

- NIST SP 800-61 Rev. 2 — ciclo de vida de gestión de incidentes.
- MITRE ATT&CK — Impact (TA0040): T1498 Network Denial of Service, T1499 Endpoint Denial of Service y sub-técnicas.
- SANS Incident Handler's Handbook — estructura PICERL y buenas prácticas operativas.
- ISO/IEC 27035 — gestión de incidentes, roles, comunicación y mejora continua.

3. Trigger / Criterios de Activación

Este playbook se activa formalmente ante cualquiera de los siguientes eventos:

- Alerta de la herramienta de monitorización de red (NetFlow, PRTG, Zabbix) indicando que el tráfico entrante supera el umbral definido (>X Gbps o >Y Mpps durante más de Z minutos consecutivos). [Parametrizar con valores reales de la organización antes de operacionalizar.]
- Alerta del proveedor anti-DDoS en la nube (Cloudflare, AWS Shield, Akamai) indicando que se está mitigando un ataque activo contra la organización.

- Degradación severa o caída de servicios web públicos sin causa interna identificada.
- Notificación del ISP o proveedor de tránsito sobre tráfico anómalo hacia los bloques IP de la organización.
- Alerta del WAF por superación masiva de tasas de peticiones (rate limiting) desde múltiples orígenes geográficos distintos.
- Reporte de usuarios externos o clientes sobre imposibilidad de acceso a servicios públicos de la organización.



Los umbrales de activación (X Gbps, Y Mpps, Z minutos) deben parametrizarse con valores reales de la organización basados en los baselines de tráfico. Sin este requisito previo, es imposible distinguir un ataque de un pico legítimo de tráfico (lanzamiento de producto, campaña de marketing). Ver sección 6.0.

4. Roles y Responsables

Rol	Responsabilidad en el playbook	Fase principal
Analista SOC L1	Triage inicial: confirmar ataque vs. falso positivo, medir volumen, clasificar tipo (volumétrico / protocolo / capa 7)	Detección y Análisis
Analista SOC L2	Análisis profundo del vector, coordinación de la contención técnica, ajuste iterativo de reglas	Detección / Contención
Equipo de Red / NOC	Aplicar ACLs en routers de borde, coordinar BGP blackholing con el ISP (bajo autorización del IR Lead)	Contención / Erradicación
Equipo de Plataforma / DevOps	Escalar capacidad horizontal de aplicación, ajustar configuración de WAF y CDN	Contención / Erradicación
IR Lead	Activa formalmente el playbook, coordina fases, AUTORIZA el BGP blackholing (el L1 no puede activarlo de forma autónoma), aprueba comunicación externa	Todas
Proveedor anti-DDoS (externo)	Activar y ajustar el servicio de scrubbing en la nube bajo demanda. Contacto 24/7 preestablecido con SLA de activación < 15 minutos	Contención
Comunicación / PR	Gestiona mensajes de estado de servicio hacia clientes y redes sociales durante el ataque activo	Comunicación
Legal / DPO	Evalúa obligaciones regulatorias si la indisponibilidad afecta a SLAs contractuales o datos personales en tránsito	Comunicación
CISO / Dirección	Aprueba declaración de incidente mayor, comunicación externa oficial e impacto en SLA con clientes	Escalado mayor

5. Diagrama de Flujo General

El procedimiento distingue desde el triage inicial entre tráfico legítimo inusual (falso positivo), ataques volumétricos/de protocolo y ataques de capa 7. Notación: círculo = inicio/fin · rectángulo = acción · rombo = decisión · recuadro rojo = vía de contingencia manual.

→ Documento independiente: Diagrama_Flujo_DDoS_SOC-IR-043 — formato PDF (póster vectorial), Word y SVG editable. Incluye ≥3 opciones de herramientas por fase.

6. Fases del Proceso (Ciclo NIST SP 800-61)

6.0 Preparación

La preparación es la condición necesaria para que este playbook sea ejecutable. Sin baselines de tráfico y sin el proveedor anti-DDoS preconfigurado, la respuesta parte de cero en el peor momento posible.

- **Baselines de tráfico (requisito operativo, no opcional):** establecer y mantener baselines de tráfico (pps y bps) por servicio y período, actualizados mensualmente. Sin este dato es imposible distinguir un ataque de un pico legítimo.
- **Servicio anti-DDoS en la nube preconfigurado:** contratar y configurar previamente Cloudflare Magic Transit, AWS Shield Advanced o Akamai Prolexic para activación en menos de 15 minutos. Documentar el procedimiento de activación y probarlo al menos una vez al año en modo de prueba.
- **Contacto 24/7 con ISP y proveedor de tránsito:** documentar el contacto de urgencia (nombre, teléfono directo, número de cuenta) con el ISP para solicitar BGP blackholing o desvío de tráfico. Verificar los SLAs de respuesta comprometidos ANTES de que ocurra un ataque.
- Exigir protección anti-spoofing BCP38/BCP84 en la infraestructura propia y solicitar su cumplimiento a proveedores de conectividad.
- Definir umbrales de activación del playbook y configurar alertas automáticas en las herramientas de monitorización con los valores reales de la organización.

6.1 Detección y Análisis

- **Triage inicial — ¿es un ataque o un pico legítimo?** comparar el tráfico anómalo contra las baselines y el calendario de eventos de negocio. Un lanzamiento de producto o campaña de marketing puede generar picos que parecen ataques volumétricos.
- **Medición y caracterización:** registrar volumen (bps), paquetes por segundo (pps), distribución geográfica y de origen (ASN), protocolos y destinos afectados.
- **Clasificación obligatoria del tipo de ataque:**
 - **Volumétrico:** satura el ancho de banda de red (UDP flood, amplificación DNS/NTP, ICMP flood). Mitigación: scrubbing center / BGP blackholing.
 - **De protocolo:** agota recursos de estado del firewall o la pila TCP (SYN flood, IP fragmentation). Mitigación: SYN proxy en firewall / FortiDDoS.
 - **Capa 7:** agota recursos del servidor de aplicación (HTTP flood, Slowloris, scraping masivo). Mitigación: WAF con rate limiting y CAPTCHA challenge.

- **Notificación inmediata:** si el tráfico supera el umbral de activación, notificar al IR Lead y abrir el ticket crítico SIN esperar a completar el análisis de vectores. El análisis continúa en paralelo a la contención.

6.2 Contención



BGP blackholing es una medida de ÚLTIMO RECURSO que implica aceptar la indisponibilidad total de la IP atacada como mal menor frente a la saturación del enlace. Requiere autorización explícita del IR Lead. El Analista L1 NO puede activarlo de forma autónoma.

- **Activar scrubbing center:** redirigir el tráfico entrante a través del proveedor anti-DDoS en la nube (vía BGP anycast o cambio de DNS) para filtrar el tráfico malicioso antes de que llegue a la infraestructura. Esta es la primera medida para ataques volumétricos.
- **Ataques volumétricos — BGP blackholing (RTBH):** si el scrubbing center no es suficiente, coordinar con el ISP para anunciar el prefijo atacado en la comunidad de blackhole. Acción autorizada solo por el IR Lead.
- **Ataques de capa 7 — WAF y rate limiting:** activar reglas de rate limiting, CAPTCHA challenge y filtrado por firma TLS/HTTP para distinguir bots del tráfico legítimo. NO usar BGP blackholing para ataques de capa 7.
- **Punto de control — ¿el tráfico legítimo llega con normalidad?** verificar activamente que los controles de mitigación no estén bloqueando usuarios reales. Si hay impacto en tráfico legítimo: ajustar las reglas de filtrado ANTES de continuar.
- **Comunicar al NOC:** estado de la contención y ETA estimado de resolución cada 15-30 minutos.
- **Preservar evidencia:** capturar logs NetFlow/pcap del ataque para análisis forense posterior sin interrumpir las acciones de mitigación activas.

6.3 Erradicación / Mitigación

- Refinar las reglas de mitigación basadas en el análisis del tráfico filtrado, eliminando reglas demasiado amplias que generan falsos positivos sobre tráfico legítimo.
- Aplicar ACLs en el router de borde y en el firewall perimetral bloqueando los rangos de IP y ASN de origen confirmados como maliciosos.
- **Validar origen de IPs:** verificar si las IPs de origen son reales o spoofed mediante uRPF (Unicast Reverse Path Forwarding) o análisis de TTL. Las IPs spoofed requieren una estrategia de bloqueo diferente a las IPs reales de botnet.
- Coordinar con el ISP la desactivación del blackholing y la vuelta al enrutamiento normal en cuanto el scrubbing center pueda absorber el tráfico residual.
- Confirmar que el ataque ha cesado o está totalmente mitigado antes de desactivar gradualmente los controles de emergencia.

6.4 Recuperación

- Validar uno a uno los servicios afectados (disponibilidad, tiempo de respuesta, tasa de error) antes de comunicar la resolución.
- Eliminar las reglas de emergencia del WAF y las ACLs temporales que ya no sean necesarias para no bloquear tráfico legítimo.
- Publicar mensaje de estado de servicio confirmando la resolución cuando haya impacto externo visible (ver sección 10).

- **Monitorización reforzada durante mínimo 24 horas:** los atacantes frecuentemente relanzan el ataque tras una pausa corta, una vez detectan que los controles de emergencia se han desactivado. No desactivar la monitorización reforzada antes de las 24 horas aunque el ataque parezca resuelto.

6.5 Lecciones Aprendidas

- Convocar post-mortem dentro de los 5-10 días hábiles posteriores al incidente, con todos los roles de la sección 4.
- Actualizar los umbrales de detección, las baselines de tráfico y las reglas del WAF y firewall con los patrones identificados en el ataque.
- Revisar el plan de capacidad y evaluar si se justifica ampliar el ancho de banda, el scrubbing capacity contratado o la arquitectura de distribución.
- Compartir los vectores e IOCs con el CSIRT nacional o la comunidad del sector bajo el protocolo TLP adecuado.

7. Mapeo a MITRE ATT&CK

Fase	Táctica (ID)	Técnica (ID)	Evidencia / detección
Detección	Impact (TA0040)	T1498 Network Denial of Service	Tráfico volumétrico que supera el baseline (Gbps / Mpps)
Detección	Impact (TA0040)	T1498.001 Direct Network Flood	UDP/ICMP flood identificado en análisis NetFlow
Detección	Impact (TA0040)	T1498.002 Reflection Amplification	Amplificación DNS/NTP detectada por el IDS (volumen desproporcionado respecto al origen)
Detección	Impact (TA0040)	T1499 Endpoint Denial of Service	HTTP flood / Slowloris detectado en capa 7 por el WAF
Contención	Defense Evasion (TA0005)	T1036 Masquerading	Tráfico de ataque mezclado con tráfico legítimo en ataques de capa 7 para evadir rate limiting simple
Erradicación	Resource Development (TA0042)	T1584 Compromise Infrastructure	IPs de botnets o reflectores identificados en logs para bloqueo en ACLs de borde

8. Herramientas y Configuraciones Críticas

Componente	Herramientas de referencia	Configuraciones críticas
Anti-DDoS en la nube	Cloudflare Magic Transit, AWS Shield Advanced, Akamai Prolexic	Preconfigurar redireccionamiento de tráfico (BGP anycast o DNS). SLA de activación < 15 min. Probar activación en modo de prueba al menos 1 vez/año.
Monitorización de red	Kentik Network Observability, NetFlow/sFlow en SIEM, PRTG / Zabbix	Alertas sobre desviaciones del baseline (pps y bps). Exportación NetFlow v9/IPFIX habilitada. Baselines actualizadas mensualmente.
WAF y CDN	Cloudflare WAF, AWS WAF, F5 BIG-IP ASM	Rate limiting por IP/ASN. CAPTCHA challenge automático ante patrones de bot. Alertas por superación de umbral de RPS. TLS fingerprinting activo.
Firewall / Router de borde	Palo Alto NGFW, Fortinet FortiGate, Juniper MX (BGP RTBH)	uRPF en modo strict. Comunidades BGP de blackhole del ISP preconfiguradas. ACLs de emergencia documentadas y listas para activación inmediata.
Protección de aplicaciones	Radware DefensePro, F5 BIG-IP AFM, Fortinet FortiDDoS	TCP SYN proxy activo. Modo de emergencia ante umbral de pps. TLS fingerprinting para bots.
SIEM	Splunk Enterprise Security, Microsoft Sentinel, Suricata IDS	Ingesta de NetFlow y logs de WAF. Reglas de correlación para amplificación DNS/NTP y SYN flood. Alertas de desvío de baseline.
Gestión de incidentes	TheHive, ServiceNow ITSM, Jira Service Management	Plantilla DDoS con campos: volumen (Gbps/Mpps), tipo de ataque, servicios afectados, ETA de recuperación, estado de BGP blackholing.

9. Criterios de Escalado

Transición	Condición de escalado	Destinatario	Tiempo máximo
L1 → L2	Confirmación de ataque real que supera el umbral de activación	Analista SOC L2	15 minutos
L2 → Equipo de Red / NOC	Necesidad de ACLs en router de borde o BGP blackholing	Equipo de Red / NOC	30 minutos
L2 → Proveedor anti-DDoS	Activación del scrubbing center en la nube	Proveedor (soporte urgente 24/7)	15 minutos

Transición	Condición de escalado	Destinatario	Tiempo máximo
L2 → IR Lead	Indisponibilidad de servicios públicos confirmada o duración > 30 minutos	IR Lead	30 minutos
IR Lead → autoriza BGP blackholing	Scrubbing center insuficiente para absorber el ataque volumétrico	IR Lead (aprobación verbal + ticket)	INMEDIATO al detectar insuficiencia
IR Lead → CISO / Dirección	Impacto en SLA con clientes, interrupción > 1 hora o ataque multi-vector	CISO, Dirección	1 hora
IR Lead → Legal / DPO	Indisponibilidad que afecta a SLAs contractuales o datos personales en tránsito	Legal / DPO	1-2 horas
CISO → Autoridades	Ataque de gran escala o con indicio de actor estado-nación	CSIRT nacional / fuerzas de seguridad	Según marco regulatorio

10. Comunicación

- **Notificación interna inicial:** IR Lead y roles de la sección 4. Incluir hora de inicio, servicios afectados, tipo de ataque clasificado, estado de la contención y ETA de recuperación.
- **Comunicación con el NOC:** actualización cada 15-30 minutos sobre el estado de la mitigación y si el tráfico legítimo está pasando con normalidad. El NOC necesita saber si puede intervenir o si el aislamiento es controlado.
- **Página de estado de servicio:** ante caídas visibles para clientes, publicar un mensaje que confirme que se está investigando y working on it, SIN revelar detalles técnicos del tipo de ataque o vectores que puedan ayudar al atacante a ajustar su estrategia.
- **Comunicación externa oficial:** gestionada exclusivamente por Comunicación/PR bajo aprobación de Dirección. Ningún miembro técnico hace declaraciones externas durante el ataque activo.
- **Notificación regulatoria:** Legal/DPO determina si la interrupción implica obligaciones de notificación (NIS2, RGPD, normativa sectorial aplicable).

11. Métricas de Cierre

- **MTTD (Mean Time to Detect):** tiempo desde el inicio del ataque hasta la generación de la alerta en la herramienta de monitorización.
- **MTTC (Mean Time to Contain):** tiempo desde la alerta hasta la activación confirmada de la mitigación (scrubbing center activo o blackholing aplicado). Esta es la métrica más crítica del playbook.
- **MTTR (Mean Time to Recover):** tiempo desde el inicio de la contención hasta la disponibilidad confirmada de todos los servicios afectados.
- **Volumen máximo del ataque:** Gbps y Mpps registrados en el pico. Dato clave para revisar el contrato de scrubbing capacity.

Evidencia mínima a documentar para el cierre:

- Cronograma completo: inicio del ataque, activación de cada medida de mitigación y recuperación de cada servicio (con timestamps).
- Volumen máximo del ataque (Gbps / Mpps) y duración total.
- Tipo de ataque confirmado y vectores identificados (UDP flood / SYN flood / HTTP flood / amplificación).
- Servicios afectados y tiempo de indisponibilidad de cada uno.
- Medidas de contención y erradicación aplicadas con timestamps y responsables.
- ¿Se activó BGP blackholing? ¿Quién lo autorizó? ¿Cuánto tiempo estuvo activo?
- Resultado del punto de control de tráfico legítimo (¿hubo denegación de servicio auto-infligida?).
- Hallazgos de lecciones aprendidas y cambios aplicados al playbook.

12. Revisión y Mantenimiento

1. Este playbook se revisa semestralmente o tras cualquier ataque DDoS significativo, conforme al ciclo de mejora continua de ISO/IEC 27035.
2. Los umbrales de activación (sección 3) deben revisarse trimestralmente contra las baselines de tráfico actualizadas.
3. El procedimiento de activación del proveedor anti-DDoS debe probarse mediante un simulacro de activación planificado al menos una vez al año.
4. Los roles de la sección 4 deben validarse trimestralmente contra el esquema de guardias vigente del SOC y el NOC.
5. El contacto 24/7 con el ISP y el proveedor anti-DDoS debe verificarse semestralmente (rotación de personal de contacto).

13. Control de Versiones

Versión	Fecha	Cambios	Autor
1.0	21 jun. 2026	Versión inicial: ciclo NIST íntegro, clasificación triple volumétrico/protocolo/capa 7, BGP blackholing con autorización IR Lead, coordinación ISP como paso crítico, monitorización reforzada 24h post-ataque, punto de control de tráfico legítimo, mapeo MITRE (T1498/T1499/T1584), métricas con volumen máximo y diagrama de flujo granular	SOC